



רסומנט



目录

1. 事件概述	3
2. 调查过程与主要发现	3
2.1 安全产品相关的恶意活动	3
2.2 攻击者使用高度定制化提币工具进行盗币	3
2.3 资金转出与后续提现尝试	4
免责与声明	5

1. 事件概述

2026 年 9 月 25 日，SlowMist 安全团队受 Bitget 团队邀请，参与此次热钱包资产被盗事件的调查。目前(截至 9 月 29 日)，我们已发现两款第三方安全产品及钱包业务主机上的恶意活动，并通过数据恢复取得了攻击者使用的定制提币工具，我们仍在追查各系统之间的具体入侵过程。

以下为截至 9 月 29 日的调查进展。文中涉及的两款第三方安全产品分别以 A、B 代称，时间均为 UTC+8。

2. 调查过程与主要发现

2.1 安全产品相关的恶意活动

现有日志中，最早的恶意活动出现在 8 月 31 日。安全产品 A 的一台节点服务存在 0 day 漏洞，攻击者在服务进程下运行了隐藏脚本，启动读取数据库密码环境变量的命令、连接数据库。9 月 23 日和 9 月 25 日，另外两台节点也出现了同类隐藏脚本活动。这表明，在资产被转出之前，相关服务环境已经遭到入侵。

9 月 25 日凌晨，攻击者冒用内部员工账号访问安全产品 B 的管理平台。00:07 起，攻击者连续三次在安全产品 B 的任务参数中拼接系统命令，尝试写入恶意文件。此后，攻击者又通过平台的 Web 执行入口提交代码，尝试修改服务器配置、写入通信中继文件，并分批上传、拼装恶意程序文件。

2.2 攻击者使用高度定制化提币工具进行盗币

调查中的一项关键发现，是从攻击者删除的文件中恢复出中高度定制化的提币工具。该工具按照钱包系统的提币业务逻辑编写，在代码中伪造风控参数，构造提币请求并调用提币流程。主机日志显示，9 月 25 日 01:49 起，相关恶意程序开始运行并且实施盗币。

* The information enclosed is intended solely for the use of the designated recipient(s).

* Any unauthorized use, disclosure, or distribution of this report is strictly prohibited.

2.3 资金转出与后续提现尝试

链上核对结果显示，目前已核实的最早一笔转出发生在 9 月 25 日 02:31:00，攻击者地址收到 93 TRX；11 秒后，以太坊上的收款地址收到 0.84 ETH。已整理的转出记录持续至当日 05:23:11，前后约 2 小时 52 分钟，涉及多条区块链。

在资金已经开始转出后，攻击者还尝试直接修改钱包数据库中的提现记录，并调用本机提现任务。日志记录了两笔人为构造的 BTC 订单进入业务处理后报错，以及攻击者随后查看日志、查询订单状态和再次尝试的过程。这部分操作发生在 05:22 之后，属于后续的 BTC 提现尝试。

免责与声明

SlowMist 根据本报告发布前发生或存在的事实发布本报告，并仅基于这些事实承担相应的责任。对于本报告发布后发生或存在的事实，SlowMist 无法判断本项目的安全状况，对此不承担责任。本报告的安全分析和其他内容均基于信息提供方至报告日期（以下简称“提供信息”）提供给 SlowMist 的文件和材料。SlowMist 假设：提供的信息无缺失、篡改、删除或隐瞒。如果提供的信息缺失、篡改、删除、隐瞒或与实际情况不符，SlowMist 对此造成的任何损失或不良影响不承担责任。SlowMist 仅对项目的安全状况进行约定的安全分析并发布本报告。SlowMist 不对项目的背景和其他条件承担责任。

** The information enclosed is intended solely for the use of the designated recipient(s).*

** Any unauthorized use, disclosure, or distribution of this report is strictly prohibited.*



Official Website

www.slowmist.com



E-mail

team@slowmist.com



Twitter

[@SlowMist_Team](https://twitter.com/SlowMist_Team)



Github

<https://github.com/slowmist>